

SBSEG 2026 · BÚZIOS, RJ · 1 A 4 DE SETEMBRO

Uma medição de segurança das imagens do Docker Hub por amostra aleatória uniforme



Cristhian Kapelinski · Diego Kreutz
AI Horizon Labs · UNIPAMPA



AI HORIZON
LABS
Explorando Novas Fronteiras da Inteligência Artificial



0 registro público de imagens de contêiner.

15 milhões

repositórios no Docker Hub ·
2024

JFrog Security research discovers
coordinated attacks on Docker Hub
that planted millions of malicious
repositories



318 bilhões

downloads, alta de 145% em
um ano · 2021

Docker Index Shows Continued
Massive Developer Adoption
and Activity to Build and Share
Apps with Docker



10 mil

imagens vazando credencial viva · 2025

**Thousands Of Exposed Secrets
Found On Docker Hub, Putting
Organizations At Risk**



**Todo estudo escolhe um subconjunto,
e a regra de escolha define a população.**



Só a última linha sorteia

Família	Imagens	Scanners	Sorteia?
Classe ou categoria	até 2,2 mi	1	×
Popularidade	33.952	1	×
Longitudinal	380	6	×
Bases de SO	5.606	14	×
Exposição	52.895	6	×
Este trabalho	2.879	6	✓

Contra o que se compara

O nosso estudo anterior, do mesmo crawl:

52.895

imagens ranqueadas por exposição

Mesma lista, mesmas ferramentas. Só a regra de seleção muda.

De 12,7 milhões a 2.879 imagens

12.716.568 Repositórios enumerados

4.800 Repositórios sorteados



2.879 Escaneadas · ± 1 p.p. a 95%

De 12,7 milhões a 2.879 imagens

12.716.568 Repositórios enumerados

4.800 Repositórios sorteados

2.879 Escaneadas · ± 1 p.p. a 95%

De 12,7 milhões a 2.879 imagens

12.716.568 Repositórios enumerados



4.800 Repositórios sorteados

2.879 Escaneadas · ± 1 p.p. a 95%

Imagem típica

Uma imagem aleatória, com tag latest.

- **latest é a tag padrão do registro**
- **Não é a mais baixada, nem a mais exposta**

0 mesmo processo nas duas amostras

1 · imagem uma imagem por repositório

2 · scanners seis, mesma configuração

3 · eixos SBOM, pacote, configuração, segredo

As duas amostras mudam só na seleção.

0 mesmo processo nas duas amostras

1 · imagem uma imagem por repositório

2 · scanners seis, mesma configuração

3 · eixos SBOM, pacote, configuração, segredo

As duas amostras mudam só na seleção.

0 mesmo processo nas duas amostras

1 · imagem uma imagem por repositório

2 · scanners seis, mesma configuração

3 · eixos SBOM, pacote, configuração, segredo

As duas amostras mudam só na seleção.

Eixo de inventário: Syft

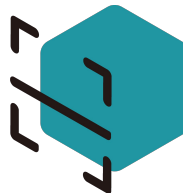


syft

Syft
inventário



Trivy
vulnerabilidades



Dockle
configuração



grype

Grype
vulnerabilidades



TruffleHog
segredos



OSV
vulnerabilidades

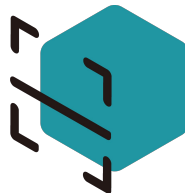
Eixo de vulnerabilidade: três scanners



syft

Syft

inventário



Dockle

configuração



TruffleHog

secrets



Trivy

vulnerabilidades



grype

Grype

vulnerabilidades



OSV

vulnerabilidades

Eixo de configuração: Dockle

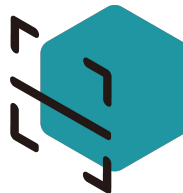


syft

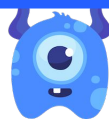
Syft
inventário



Trivy
vulnerabilidades



Dockle
configuração



grype

Grype
vulnerabilidades



TruffleHog
segredos



OSV
vulnerabilidades

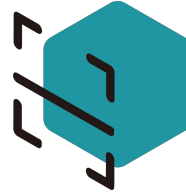
Eixo de segredo: TruffleHog



Syft
inventário



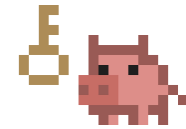
Trivy
vulnerabilidades



Dockle
configuração



Grype
vulnerabilidades



TruffleHog
segredos

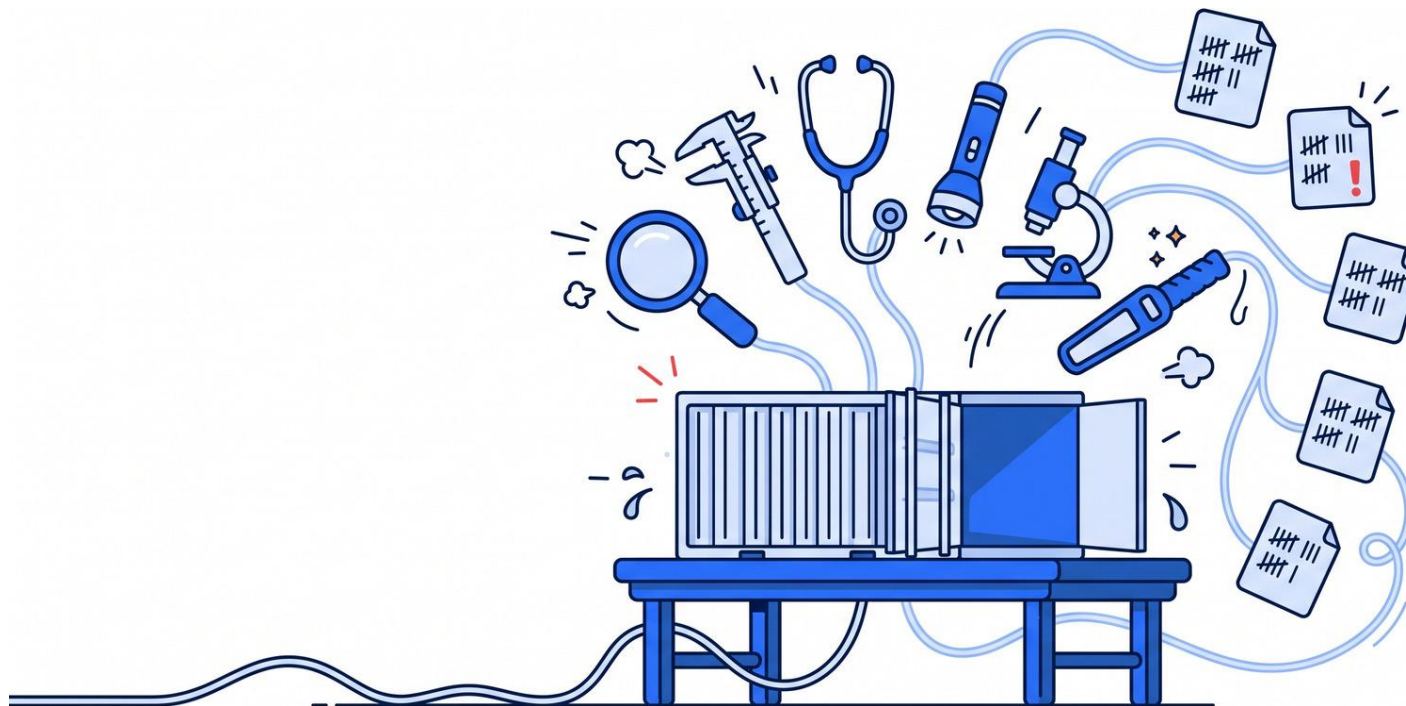


OSV
vulnerabilidades

02

Avaliação experimental

O que as duas
amostras
mostram



Um terço não tem tag latest

Dos 4.800 repositórios sorteados



São repositórios parados: metade sem envio novo desde 2023.

Os outros 248

113

não baixam: manifesto ou artefato OCI

57

o scan travou: scanner preso ou tempo
esgotado

42

acesso negado: privado ou apagado

36

só existe em outra arquitetura

Vulnerabilidades

Das 2.879 escaneadas,

94,4%

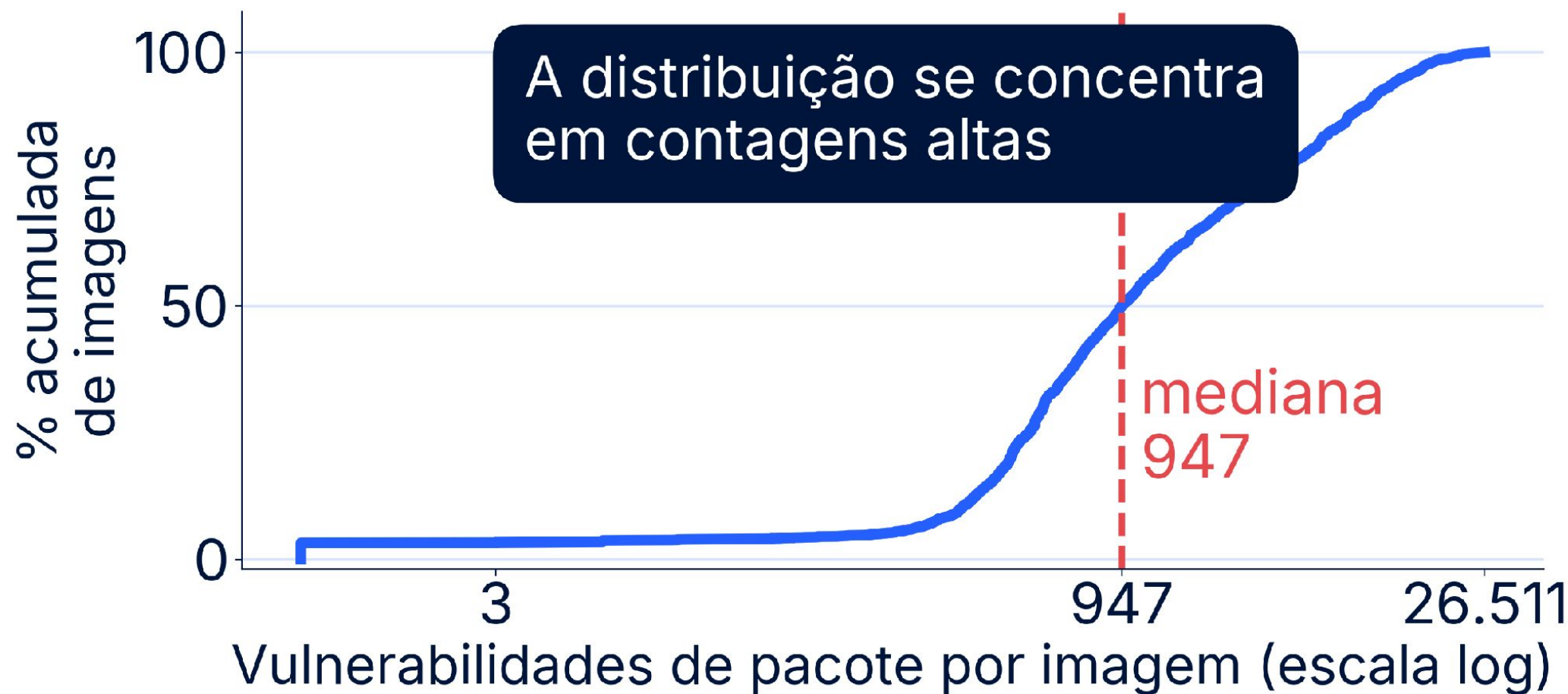
com crítica

E das mesmas 2.879,

96,8%

com alguma

Metade passa de 947 vulnerabilidades



A mais baixada não é mais bem mantida

Métrica	Aleatória	Mais exposta
Imagens escaneadas	2.879	52.895
Ao menos 1 crítica	94,4%	93,4%
Ao menos 1 alta	96,1%	95,5%
Segredo (bruto)	82,4%	76,9%

A mais baixada não é mais bem mantida

Métrica	Aleatória	Mais exposta
Imagens escaneadas	2.879	52.895
Ao menos 1 crítica	94,4%	93,4%
Ao menos 1 alta	96,1%	95,5%
Segredo (bruto)	82,4%	76,9%

A mais baixada não é mais bem mantida

Métrica	Aleatória	Mais exposta
Imagens escaneadas	2.879	52.895
Ao menos 1 crítica	94,4%	93,4%
Ao menos 1 alta	96,1%	95,5%
Segredo (bruto)	82,4%	76,9%

A mais baixada não é mais bem mantida

Métrica	Aleatória	Mais exposta
Imagens escaneadas	2.879	52.895
Ao menos 1 crítica	94,4%	93,4%
Ao menos 1 alta	96,1%	95,5%
Segredo (bruto)	82,4%	76,9%

A mais baixada não é mais bem mantida

Métrica	Aleatória	Mais exposta
Imagens escaneadas	2.879	52.895
Ao menos 1 crítica	94,4%	93,4%
Ao menos 1 alta	96,1%	95,5%
Segredo (bruto)	82,4%	76,9%

Segredos

O TruffleHog sinaliza
82,4% das imagens

Do que foi revisado,
99,5% eram falso
positivo

**5 de 1.100 eram credencial:
chave SSH de host, duas chaves AWS,
chave de API do Google, chave privada em código.
O resto: hash de pacote (60%), placeholder (18%).**

Configuração

Das 2.879 imagens escaneadas,

99,4%

têm algum achado de configuração.

Achados de configuração

- **97,4% sem sonda de saúde (HEALTHCHECK)**
- **89,0% rodando como root**
- **31,7% com valor sensível em variável ou arquivo**

Concordância entre scanners

Só um scanner viu
70,5% dos achados

Os três scanners viram
11,1% dos achados

O par mais parecido compartilha 43% dos achados.

03

Conclusões

O que o sorteio
muda na decisão



Contribuição

- Sorteio uniforme no Docker Hub
- A postura da imagem típica, medida

Resultado

- **94,4% das típicas contra 93,4% das expostas**
- **Mais usada não quer dizer mais bem mantida**

Limitações

- **Só linux/amd64**
- **A unidade é a tag latest, não todas as versões**



Obrigado!

Perguntas são bem-vindas

AUTOR DE CONTATO

Cristhian Kapelinski

`cristhianavila.aluno@unipampa.edu.br`



Artigo Artefato AI Horizon



Apoio



FAPERGS

Fundação de Amparo à Pesquisa do Estado do Rio Grande do Sul



Basta 2.879 para 12,7 milhões?

- **2.879** escaneadas, sorteadas de 12.716.568
- **Margem** abaixo de 1 ponto, Wilson, 95%
- **Uniforme** sem estrato, peso ou efeito de desenho
- **Fora do alcance** cauda rara e série no tempo

A estimativa é de prevalência, não de impacto.

Por que 12,7 milhões e não 15?

- **12.716.568** nomes que o crawl enumerou
- **15 milhões** total citado pela JFrog em 2024
- **A diferença** privado e não enumerável, ~15%
- **Uniforme** dentro do quadro, não fora dele

O quadro é o crawl, não o Docker Hub inteiro.

Quem ficou fora do escaneamento

- **4.800** sorteados; 2.879 escanearam, 60,0%
- **1.673** sem tag latest, 34,9%
- **Auditoria** 200 refeitos: 199 seguem sem latest
- **248** 113, 57, 42 e 36, por quatro motivos

Sobre os 4.800, a crítica fica entre 56,6% e 96,6%.

Um ponto de diferença, $p = 0,03$

- **2.718 de 2.879** 94,4%, contra 49.392 de 52.895
- **$z = 2,17$** $p = 0,03$: distinguível, e pequeno
- **0,15 e 0,23** alta e qualquer: não distinguem
- **O sinal** pende para a amostra aleatória

Com 52.895 de um lado, o teste enxerga um ponto.

Um terço das imagens sem Trivy

- **971** imagens sem Trivy, 33,7%
- **915** dessas, por disputa do cache
- **96,1%** tiveram cinco dos seis; 62,7%, os seis
- **Efeito** o que falta não entra: fica conservador

Não sabemos se a falha depende do tipo de imagem.

Qual scanner está certo?

- **Jaccard** $0,43 \cdot 0,23 \cdot 0,18$, par a par
- **Volume** Trivy 1,68 mi, Grype 680 mil, OSV 435 mil
- **1.817** imagens em que os três rodaram
- **Nessas** 72,7% em um só, 13,8% nos três

Nenhum é referência: medimos dependência, não acerto.

82,4% de segredo, 99,5% falso

- **82,4%** taxa bruta do TruffleHog, sem filtro
- **1.100** de 169.528, semente 20260522
- **Cinco** credenciais reais; IC 98,9 a 99,8%
- **Um revisor** sem segundo rotulador

**Sem verificação ativa: os rótulos julgam
plausibilidade, não credencial viva.**

947 ou 260 por imagem?

- **947** mediana mesclada, com duplicata
- **260** mediana de CVE distinto; máximo 8.265
- **94,4%** a fração afetada não muda
- **601** mediana de Zerouali 2018, em Debian

Definição diferente: a comparação é indicativa.

Crítica quer dizer explorável?

- **Não medimos** se o código vulnerável é chamado
- **Herança** a base propaga o CVE à derivada
- **zlib** vulnerável em 90,5% das imagens
- **openssl** em 86,1%: vem da base, não do autor

A taxa mede a superfície publicada, não o risco em uso.

Escopo: 4.800, amd64, latest

- **4.800** sobressorteio: 40% não escaneiam
- **linux/amd64** exclui 36 dos 4.800, ou 0,75%
- **latest** o que o usuário recebe sem pedir versão
- **Zero oficial** ~160 em 12,7 mi: esperado 0,06

Tag flutuante e base de CVE em movimento: vale a campanha.

Análises anteriores, lado a lado

Estudo	Reportado	Aleatória
Shu 2017 · pior severidade	alta	crítica
Liu 2020 · comunidade	>64%	96,4%
Zerouali 2019 · mediana	601	947
Dahlmanns 2023 · segredo	8,5%	82,4%
Churakova 2025 · Jaccard	0,69	0,43

Indicativo: scanner, amostra e unidade diferem.

Direções

- **Longitudinal** separa queda de abandono
- **Base e data** testaria a herança, hoje inferida
- **Ponderado** prevalência e alcance num estimador

Nenhuma das duas amostras dá os dois hoje.